

Pwning a Cisco RV340 漏洞分析 (CVE-2022-20705 和 CVE-2022-20707)

SWING 2022-04-02 | 📖 漏洞分析 | 🏷️ CVE-2022-20705, CVE-2022-20707, cisco

原作者用到了四个漏洞， 我这里简单分析其中两个， 分别是 CVE-2022-20705 和 CVE-2022-20707

漏洞描述

影响版本: RV34X-v1.0.03.22-2021-06-14-02-33-28-AM.img

[Relyze Software Limited – Advanced Software Analysis: Pwning a Cisco RV340 with a 4 bug chain exploit](#)

固件下载

[Software Download – Cisco Systems](#)

CVE-2022-20705 Improper Session Management Vulnerability

Nginx 配置不当加上 upload.cgi 对 cookie 两者处理不一致导致的授权绕过。

首先 nginx 对 upload 模块的 session 的处理如下:

```
1 $ cat web.upload.conf
2 location /form-file-upload {
3     include uwsgi_params;
4     proxy_buffering off;
5     uwsgi_modifier1 9;
6     uwsgi_pass 127.0.0.1:9003;
7     uwsgi_read_timeout 3600;
8     uwsgi_send_timeout 3600;
9 }
10
11 location /upload {
12     set $deny 1;
13
14     if (-f /tmp/websession/token/$cookie_sessionid) {
15         set $deny "0";
16     }
17
18     if ($deny = "1") {
19         return 403;
20     }
```

```

21
22     upload_pass /form-file-upload;
23     upload_store /tmp/upload;
24     upload_store_access user:rw group:rw all:rw;
25     upload_set_form_field $upload_field_name.name "$upload_file_name";
26     upload_set_form_field $upload_field_name.content_type "$upload_content_ty
27     upload_set_form_field $upload_field_name.path "$upload_tmp_path";
28     upload_aggregate_form_field "$upload_field_name.md5" "$upload_file_md5";
29     upload_aggregate_form_field "$upload_field_name.size" "$upload_file_size"
30     upload_pass_form_field "^.*$";
31     upload_cleanup 400 404 499 500-505;
32     upload_resumable on;
33 }

```

可以发现， 这里是判断如果 `/tmp/websession/token/$cookie_sessionid` 文件存在,则返回。 注意这里的 `$cookie_sessionid` 是由用户在 HTTP 请求中传入的。可以看到这里的文件没有判断是否存在 `../..`。因此如果我们跨目录指向一个存在的文件就可能造成授权绕过。像这里作者使用的是 `../..../etc/firmware_version`。

虽然在 `upload.cgi` 对 HTTP_COOKIE 进行了正则校验

```

1  v16 = strcmp_1(REQUEST_URI, "/api/operations/ciscosb-file:form-file-upload");
2  if (v16 != 0) {
3      v17 = strcmp_1(REQUEST_URI, "/upload");
4      if (v17 == 0 && HTTP_COOKIE != 0) { // if the URI is /upload and we have a se
5          v18 = strlen_1(HTTP_COOKIE);
6          if (v18 < 81) { // sanity check sessionid characters
7              v19 = match_regex("[A-Za-z0-9+="/>*$)", HTTP_COOKIE);
8              if (v19 == 0) {
9                  v20 = StrBufToStr(local_0x44);
10                 func_0x2684(HTTP_COOKIE, content_destination, content_option, con
11             }
12         }
13     }
14 }

```

但是在程序没有考虑用户在 HTTP cookie 中传入多个 session_id 的情况

```

1  if (HTTP_COOKIE != 0) { // if an cookie is available
2      StrBufSetStr(cookie_str, HTTP_COOKIE);
3      __s2 = StrBufToStr(cookie_str);
4      next_semicolon = strtok_r(__s2, ";", &saveptr); // start to split the semicol
5      HTTP_COOKIE = 0; // this variable will become the sessionid string

```

```

6     while (next_semicolon != 0) {
7         sessionid = strstr(next_semicolon, "sessionid=");
8         if (sessionid != 0) { // advance past "sessionid=" and set the value
9
10             HTTP_COOKIE = sessionid + 10; // advance past "sessionid=" and set th
11
12         }
13         next_semicolon = strtok_r(0, ";", &saveptr); // keep searching
14     }
15 }

```

那么如果设置两个 sessionid，第一个为 `../../../../etc/frimware_version`，第二个为可以通过正则的有效字符。

最后我们就可以用授权的状态访问 `upload.cgi` 了。

CVE-2022-20707 Command Injection

作者在 `upload.cgi` 里找到了一个命令注入。

```

1  if (json_obj != 0) {
2
3  json_str = json_object_to_json_string(json_obj);
4
5  sprintf(&buff, "curl %s --cookie 'sessionid=%s' -X POST -H 'Content-Type: applica
6
7  debug("curl_cmd=%s", &buff);
8
9  __stream = popen(&buff, "r");
10
11  if (__stream != 0) {
12
13  fread_1(&buff[2048], 2048, 1, __stream);
14
15  fclose_1(__stream);
16
17  }

```

这里的 `json_str` 没有校验，会造成命令注入。

Related vulnerability tracking

我们之前分析了 CVE-2022-20699-cisco-RV34X 的时候，注意到一个补丁， 修补了 Nginx 的配置不当的漏洞。然后今天和 @leommxj 一起追溯了一下 cisco 的修补历史。

Firmware version 1.0.03.19

nginx 对调用 upload.cgi 没有任何的校验， 因此可以访问 upload.cgi ， 还出两个漏洞 #CVE-2020-3451 #CVE-2020-3453

相关的漏洞信息为：

ZDI-20-1100 | Zero Day Initiative
ZDI-20-1101 | Zero Day Initiative
Cisco Small Business RV340 Series Routers Command Injection and Remote Code Execution Vulnerabilities

Firmware version 1.0.03.21

之后有个老哥发现 cisco 虽然加行了授权校验，但是加得不行。

这加之前和加之后的 diff:

```
6 | uwsgi_read_timeout 3600;
7 | uwsgi_send_timeout 3600;
8 | }
9 |
10 | location /upload {
11 |
12 |
13 |
14 |
15 |
16 |
17 |
18 |
19 |
20 |
21 |
22 |
23 |
24 |
25 |
26 |
27 |
28 |
29 |
30 |

6 | uwsgi_read_timeout 3600;
7 | uwsgi_send_timeout 3600;
8 | }
9 |
10 | location /upload {
11+ | set $deny 1;
12+ |
13+ |     if ($http_authorization != "") {
14+ |         set $deny "0";
15+ |     }
16+ |
17+ |     if (-f /tmp/websession/token/$cookie_sessionid) {
18+ |         set $deny "0";
19+ |     }
20+ |
21+ |     if ($deny = "1") {
22+ |         return 403;
23+ |     }
24+ |
25 | upload_pass /form-file-upload;
26 | upload_store /tmp/upload;
27 | upload_store_access user:rw group:rw all:rw;
28 | upload_set_form_field $upload_field_name.name "$upload
29 | upload_set_form_field $upload_field_name.content_type '
30 | upload_set_form_field $upload_field_name.path "$upload
```

这个修复有一个致命的缺陷。逻辑是这样的，任何非空的授权标头都会将 \$deny 设置为“0”。因此，从字面上发送任何看起来有效的授权标头作为请求/上传的一部分将绕过授权检查。

相关漏洞信息为：

#CVE-2021-1473 #CVE-2021-1472
Advisory: Cisco RV34X Series – Authentication Bypass and Remote Command Execution – IoT Inspector (iot-inspector.com)

Firmware version 1.0.03.22

然后这个版本之后去掉了上图 13 行的 nginx 配置。但是出现了此次 CVE-2022-20705 这个漏洞了。

Firmware version 1.0.0.3.26

最新版本的 nginx 现在配置文件如下：

```
1  location /upload {
2      set $deny 0;
3
4      if (-f /tmp/websession/token/$cookie_sessionid) {
5          set $deny "${deny}1";
6      }
7
8      if ($cookie_sessionid ~* "^[a-f0-9]{64}") {
9          set $deny "${deny}2";
10     }
11
12     if ($deny != "012") {
13         return 403;
14     }
15 }
```

增加了一个正则判断。

other

一个点有意思的是， 这CVE-2022-20705 作者 和 CVE-2021-1473 作者用到的命令注入和我当时挖到两个编号 #CVE-2021-1609 和 #CVE-2021-1610 的漏洞点在一行代码里，这意思就是这行代码一共出了 4 个漏洞编号

以后挖 IoT 漏洞也要多注意一下 web 相关的配置了。

在 SWING 上还有

GeekPwn 参赛记

4 年前 • 4条评论

geek pwn 2018

CodeQL 的学习以及尝试漏洞挖掘

2 年前 • 4条评论

1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 ...

CVE-2020-15257 Docker (容器逃逸) 分析

2 年前 • 2条评论

1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 ...

一个脱壳的特殊方法

3 年前 • 2条评论

前言 前段时候遇到了 Themida,

0条评论

swing

 Disqus [隐私政策](#)

 Favorite

 推文

 分享



开始讨论...

通过以下方式登录

或注册一个 DISQUS 帐号 [?](#)



姓名

来做第一个留言的人吧!

 订阅

 在您的网站上使用 Disqus添加 Disqus添加  不要出售我的数据

Copyright © 2016–2022 Swing

[Home](#)

[About](#)

[Articles](#)

[Search](#)

[RSS](#)

[Categories](#)

[Links](#)